

OmniPassport: A Real-Time, Customer-Governed AI Privacy Architecture

Concept Paper | PDPA-Aligned, Pilot-Validated Responsible AI for New Telecom Ltd.

1. Deconstruction of the Problem

New Telecom Ltd. pairs mature security controls (Zero Trust, DLP, encryption) with a missing capability: continuous accountability linking data, purpose, AI system, vendor, and customer choice into one enforceable, auditable chain. The PDPA converts this gap into binding duty — lawful basis, minimization, explainability, cross-border control, and an absolute ban on tracking minors. AI sharpens the risk further: identity, payment, location, and behavioural data can be combined to expose private lives without a breach, and a customer's erasure right is hard to honor once their data is embedded in a trained model's weights.

2. Key Privacy, Security & Ethical Challenges

- **Visibility & Accountability:** no live register connecting data, AI use, vendor, and ownership; unclear cross-border transfer basis.
- **AI-Native Security:** prompt injection, training-data extraction, model inversion, and AI-assisted impersonation across GenAI and e-KYC pipelines.
- **Ethical & Rights Gaps:** opaque profiling and fraud decisions, erasure requests colliding with data baked into trained model weights, unfair subgroup error rates.
- **Child Protection:** a shared family SIM means an adult registrant does not establish the actual user's age — a naive registration check is not enough.

3. Proposed Approach — "OmniPassport"

- **Omnichannel Privacy Cockpit:** app + *121# USSD (Bangla/English) for consent toggles and single-click access/portability/erasure; a withdrawal suppresses queued campaigns, requires vendor acknowledgement, and returns a neutral receipt safe for shared phones.
- **Real-Time Privacy Passport Engine:** every AI use case holds a versioned passport (owner, lawful basis, permitted fields, model, recipients, retention, DPIA) bound to authenticated application identity; a live gateway checks the passport and current customer preference on every request and returns ALLOW, MASK, or BLOCK.
- **Cryptographic Vault & Crypto-Erasure:** HSM-backed tokenization before AI ingestion; erasure destroys the customer's key, cryptographically severing their data from trained models without a full retrain.
- **Conservative Minor Safeguard:** since SIM registration cannot confirm the actual user's age, uncertain-age accounts default to generic, non-profiled offers; confirmed under-18 accounts are hard-blocked from all profiling and marketing AI.
- **Governance & Vendor Passport:** a live AI/data register; DPIA enforced as a CI/CD gate; differential privacy, synthetic data, and on-device inference by default; vendors scored on a Privacy Passport before procurement, with non-conforming vendors receiving no personalized data.

4. Expected Impact & Validation

Validate through a 90-day pilot — one support workflow, one campaign, one vendor: days 1-30 map flows and baseline cost, 31-60 integrate controls, 61-90 test with customers and verify safeguards independently. Launch gates: no open critical leakage, passing withdrawal/child-exclusion/outage tests, and at least 90% of a diverse 40-person sample completing opt-out unaided within two minutes. For customers: visible control, an honored erasure right, and real protection for minors. For New Telecom: audit-ready evidence, a shrunk breach footprint, and faster AI scale-up — expanded over 6-12 months only after reviewing customer harm and cost.

5. Applicability to Bangladesh

In a mobile-first economy where PDPA enforcement precedent is still developing, telecoms are natural trust anchors for fintech, health-tech, and e-commerce. Bangla USSD and assisted channels extend rights to rural, low-literacy, and shared-phone users beyond smartphone owners. The Passport Engine and pilot-gate model — grounded in the NIST AI Risk Management Framework and OWASP prompt-injection guidance — give regulators a concrete, auditable reference as PDPA guidance continues to evolve.